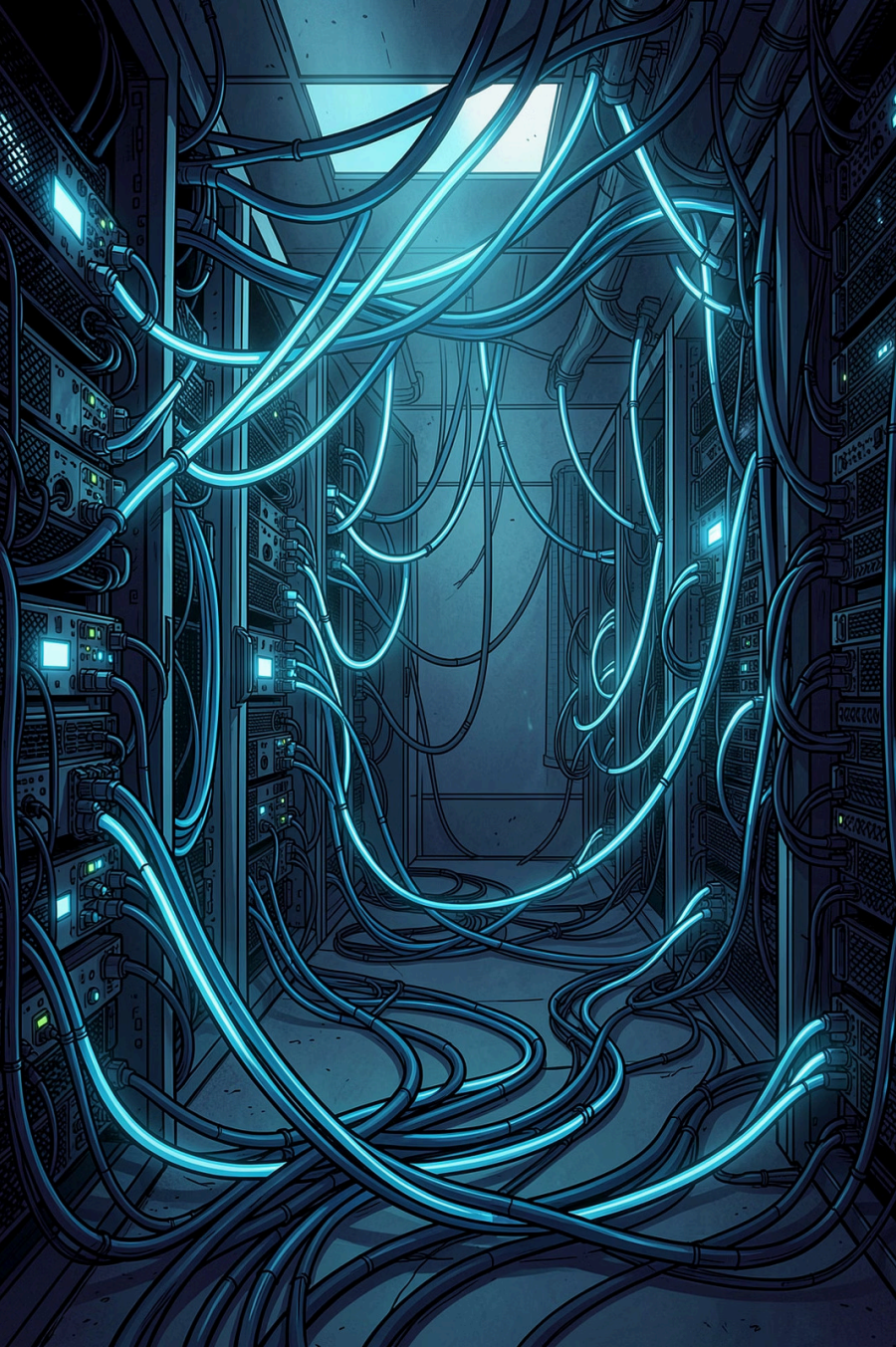




CTI-2021-KSA07 · 07/06/2026 · CRÍTICO

Investigação de Incidente: Kaseya Supply Chain Attack

Em julho de 2021, o grupo REvil/Sodinokibi explorou a vulnerabilidade CVE-2021-30116 em servidores Kaseya VSA, distribuindo uma atualização maliciosa que impactou 800 a 1.500 organizações globalmente via supply chain attack.

TTPs e Mapeamento MITRE ATT&CK

Técnicas observadas nas fases de **Initial Access**,
Execution, **Defense Evasion** e **Impact**.

T1190 /
T1195.002

Exploração CVE-
2021-30116 e
atualização
maliciosa via supply
chain

T1059.001

PowerShell para
desabilitar
Windows Defender

T1562.004 /
T1574.002

Desabilitação de
firewall e DLL Side-
Loading via
MsMpEng.exe

T1486

Criptografia com
Salsa20/RC4



Assessment e Lacunas de Inteligência

Alta Confiança

REvil tinha conhecimento prévio da vulnerabilidade; ataque planejado para maximizar impacto antes dos patches.

Velocidade e Disseminação

Sem evidências de exfiltração massiva ou C2 contínuo — foco em propagação rápida via RMM com privilégios SYSTEM.

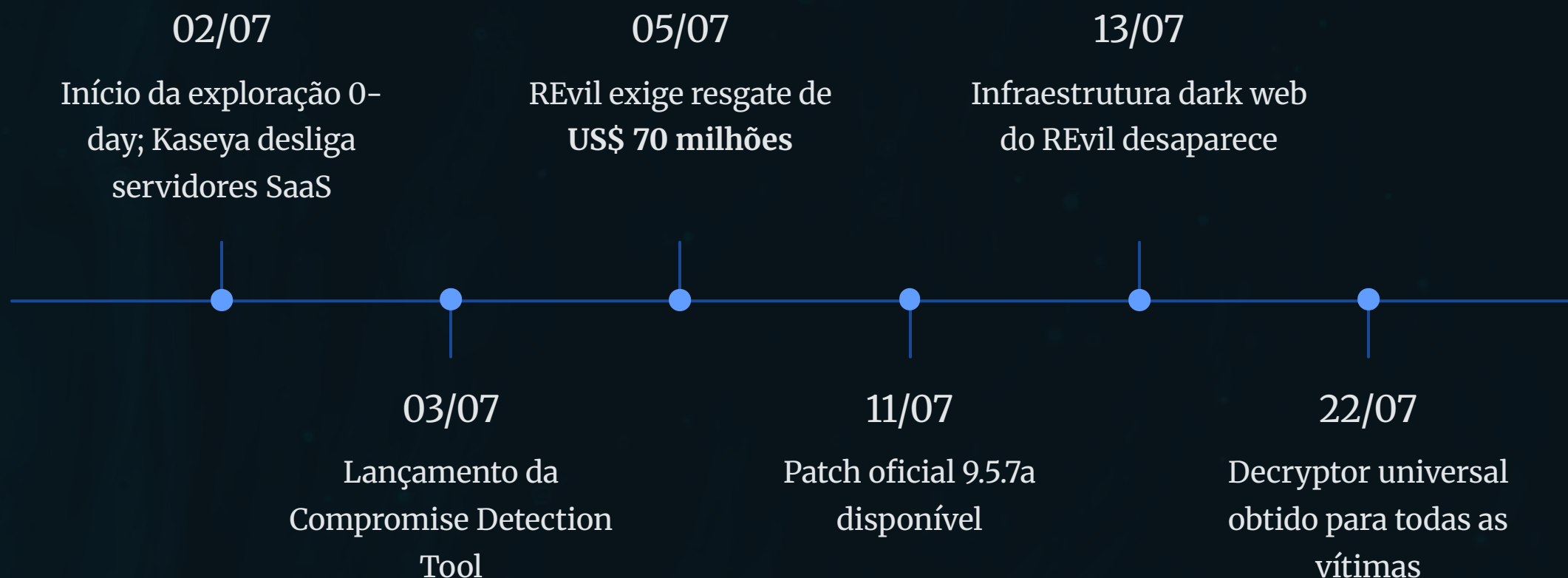
Risco Futuro

MSPs e ferramentas RMM continuarão sendo alvos prioritários pelo potencial de acesso em larga escala.

- ⚠ **Lacunas:** Origem da vulnerabilidade, acesso prévio à Kaseya, seleção de vítimas, persistência pré-detonacao e extensão da exfiltração permanecem não confirmados.



Cronograma e IOCs



Malware

- **agent.crt** — MD5:
939aae3cc456de8964cb182c75a5f8cc
- **agent.exe** — MD5:
561cffbaba71a6e8cc1cdceda990ead4
- **mpsvc.dll** — MD5:
a47cf00aedef769d60d58bfe00c0b5421

Rede & Sistema

- IPs: 35.226.94[.]113, 161.35.239[.]148, 162.253.124[.]162
- **cert.exe** — certutil renomeado para decodificação
- **MsMpEng.exe** — DLL Side-Loading

Kill Chain e Recomendações



O PowerShell ofuscado executou: `Set-MpPreference -DisableRealtimeMonitoring $true` e demais proteções, seguido de decodificação via `certutil.exe`.



Isolamento de Redes RMM

Servidores RMM em DMZs segmentadas, sem exposição direta nem credenciais compartilhadas com produção.



EDR/XDR Comportamental

Alertas para processos legítimos (MsMpEng.exe, certutil.exe) com conexões atípicas ou modificações em lote.



Hardening de PowerShell

Constrained Language Mode e monitoramento SIEM dos Event IDs 4103/4104 para comandos ofuscados.